

MASTER REFERENCE & CYBER DEFENSE BLUEPRINT

Network Security & Cyber Defense Architecture

From Layered Threat Analysis to Cryptographic Foundations, Zero Trust, NGFW & Incident Mitigation

DOMAIN: Cybersecurity & SecOps

FRAMEWORKS: NIST CSF, MITRE ATT&CK, ISO 27001

PROTOCOLS: TLS 1.3, IPsec, SSH, WPA3, DNSSEC

SECURITY: Cryptography, Firewalls, IDS/IPS, ZTA

01 Core Security Principles & Zero Trust Architecture

The CIA Triad & Expanded Security Tenets

Core

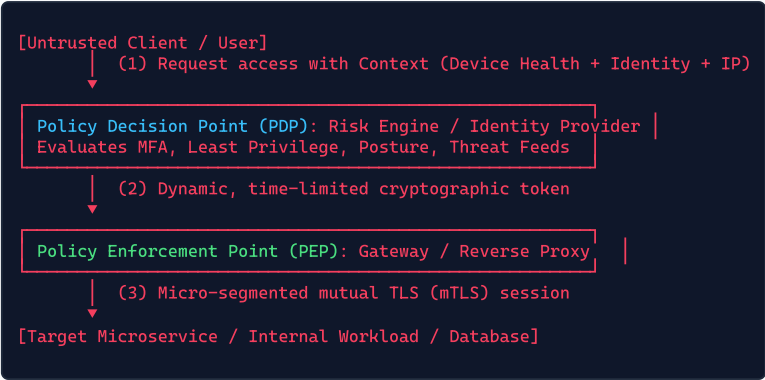
Pillar	Objective	Primary Defensive Controls
Confidentiality	Data remains shielded from unauthorized eavesdropping	Symmetric encryption (AES-256), TLS 1.3, Access Control Lists (ACLs)
Integrity	Guarantees data is unmodified and tamper-evident in transit	Cryptographic hashes (SHA-256), HMAC, Digital Signatures, PKI
Availability	Systems and services remain operational upon demand	Redundant server clustering, BGP Anycast, Anti-DDoS, RAID, Backups
Non-Repudiation	Sender cannot refute having performed the action	Asymmetric digital signatures, auditable immutable tamper-proof logs
Authenticity	Verification of entity or packet origin legitimacy	Multi-Factor Authentication (MFA), 802.1X, mutual TLS (mTLS)

Defense-in-Depth: Security must never rely on a single defensive barrier. Deploy layered defenses across Perimeter (Firewall), Network (VLANs), Host (EDR), Application (WAF), and Data (Encryption).

Zero Trust Architecture (NIST SP 800-207)

Paradigm

Radical shift from perimeter-based "Castle-and-Moat" to "Never Trust, Always Verify":



- **Explicit Verification:** Authenticate and authorize continuously based on all available data points (identity, location, device health, anomalies).
- **Least Privilege Access:** Just-In-Time (JIT) and Just-Enough-Access (JEA).
- **Assume Breach:** Minimize blast radius via microsegmentation and end-to-end encryption.

02 OSI & TCP/IP Layer Vulnerabilities and Attacks

Layer-by-Layer Attack Vectors & Defensive Countermeasures			OSI Stack
Layer	Protocol Stack	Vulnerabilities & Exploitation Methods	Countermeasures & Hardening
Layer 2: Data Link	Ethernet, ARP, 802.1Q, DHCP	• ARP Spoofing / Poisoning: Unsolicited ARP replies map attacker's MAC to gateway IP. • MAC Flooding: Exhausts switch CAM table, turning switch into a dumb hub. • DHCP Starvation / Rogue DHCP: Floods MACs to lease all pool IPs.	• Dynamic ARP Inspection (DAI) with DHCP Snooping. • Port Security: Limit maximum allowed MAC addresses per switchport. • DHCP Snooping: Designate trusted uplink ports for DHCP responses.
Layer 3: Network	IPv4, IPv6, ICMP, IPsec, BGP	• IP Spoofing: Forging source IP header for reflection attacks. • ICMP Flood / Smurf Attack: ICMP echo broadcast amplifier. • BGP Hijacking: Malicious AS path advertisement rerouting traffic globally.	• Unicast Reverse Path Forwarding (uRPF) on boundary routers. • Rate-limit or drop incoming external ICMP echo requests. • ROA / RPKI (Resource Public Key Infrastructure) route validation.
Layer 4: Transport	TCP, UDP	• TCP SYN Flood: Sends SYN packets with spoofed IPs, filling server backlog queue. • TCP Reset Attack: Injects RST packets with guessed sequence numbers. • UDP Amplification: Exploits connectionless UDP (NTP, DNS, SSDP) for 50x-500x floods.	• SYN Cookies: Stateless cryptographic encoding in initial sequence number. • Stateful firewalls with aggressive half-open connection pruning. • Disable open UDP recursors and monlist commands on internet-facing daemons.
Layer 7: Application	HTTP/S, DNS, SMTP, SSH	• DNS Cache Poisoning: Forges DNS query responses to divert domain traffic. • Slowloris: Sends partial HTTP headers slowly, holding web server worker threads. • SQLi / XSS / SSRF: Injections into unvalidated web inputs.	• DNSSEC: Cryptographic validation of DNS resource records. • Web Application Firewall (WAF) with ModSecurity / Cloudflare rules. • Strict timeouts for HTTP headers; input parameterization & sanitization.

03 Threat Actors, Malware Taxonomy & DDoS Architectures

Malware Classification

Payloads

- **Worm:** Self-replicating autonomous program exploiting network service bugs without human intervention (e.g., WannaCry, Conficker).
- **Ransomware:** Asymmetrically encrypts victim storage; demands cryptocurrency ransom. Double/Triple extortion threatens public data leakage.
- **Trojan:** Masquerades as legitimate software while establishing a covert *Command & Control (C2)* reverse shell.
- **Rootkit:** Subverts OS kernel (Ring 0) or UEFI firmware to conceal malicious processes from security tools and task managers.

DDoS Attack Taxonomy

Availability

Attacker → C2 Botnet Master

[Thousands of IoT Bots]

Volumetric
(NTP/DNS Amp)
Saturates
Bandwidth

Protocol
(SYN Flood)
Depletes
State Table

Application
(HTTP Flood)
Crashes App
Thread Pools

Mitigated via Anycast IP routing, Cloud Scrubbing Centers (Akamai, Cloudflare), and rate-limiting.

Man-in-the-Middle (MitM)

Interception

- **SSL/TLS Stripping:** Intercepts initial unencrypted HTTP redirect, downgrading HTTPS connections to plaintext.
- **Defense:** *HTTP Strict Transport Security (HSTS)* with preloading forces browser to connect exclusively over HTTPS.
- **Session Hijacking:** Stealing session tokens via packet sniffing or XSS. Fixed by **HttpOnly**, **Secure**, **SameSite=Strict** cookie flags.
- **Evil Twin:** Rogue wireless AP broadcasting legitimate SSID to harvest credentials.

04 Applied Cryptography & Public Key Infrastructure (PKI)

Symmetric vs Asymmetric Encryption

Ciphers

Attribute	Symmetric Encryption	Asymmetric (Public Key) Encryption
Key Structure	Single shared secret key for encryption & decryption	Keypair: Public Key (encrypts) + Private Key (decrypts)
Computation Speed	Extremely fast (hardware-accelerated AES-NI)	Slow (~1000× slower; intensive modular math)
Key Distribution	Hard (must securely pre-share secret key)	Easy (public key can be freely distributed)
Primary Algorithms	AES-128/256 (GCM, CBC), ChaCha20-Poly1305	RSA (2048/4096-bit), ECC (Curve25519, ECDSA)
Network Role	Bulk data transmission in TLS / IPsec payloads	Initial key exchange, digital signatures, identity auth

Diffie-Hellman Key Exchange (DH/ECDHE): Allows two parties over an untrusted channel to compute a shared secret key without ever transmitting the secret across the wire!
Ephemeral (ECDHE) generates single-session keys providing *Perfect Forward Secrecy (PFS)*.

X.509 PKI & Certificate Chain of Trust

PKI Architecture

How a client validates that an unknown server is authentic:

```
[Root CA Certificate] (Self-signed, trusted in OS/Browser Root Store)
  ↓ Signs Intermediate with Root Private Key
[Intermediate CA Certificate] (Keeps Root offline for safety)
  ↓ Signs End-Entity Certificate with Intermediate Key
[Server SSL/TLS Certificate (e.g. *.domain.com)]
- Public Key of Domain Server
- Subject Alternative Names (SAN)
- Validity Dates & Signature Algorithm
- Digital Signature from Intermediate CA
```

- **Revocation Verification:** CRL (Certificate Revocation List) & **OCSP (Online Certificate Status Protocol)**. *OCSP Stapling* attaches a timestamped CA-signed status directly to the TLS handshake, eliminating client latency.
- **Cryptographic Hashes:** SHA-256 / SHA-3 provide one-way deterministic outputs. Resistant to Pre-image and Collision attacks.

05 Secure Network Protocols: TLS 1.3, IPsec & VPNs

TLS 1.2 vs TLS 1.3 Handshake Protocol

Transport Layer

```
TLS 1.2 (2 Round-Trip Times - 2 RTT)
Client → [ClientHello (Cipher suites)] → Server
Client ← [ServerHello + Cert + KeyExchange] ← Server
Client → [ClientKeyExchange + Finished] → Server
Client ← [Session Ticket + Finished] ← Server (Data starts!)
```

```
TLS 1.3 (1 Round-Trip Time - 1 RTT Fast Handshake)
Client → [ClientHello + KeyShare (ECDHE guess)] → Server
Client ← [ServerHello + KeyShare + Cert + Fin] ← Server (Data starts!)
```

- **Modernized Security:** TLS 1.3 banned obsolete ciphers (RC4, DES, 3DES, MD5, SHA-1, static RSA key exchange, CBC modes). Only authenticated AEAD ciphers permitted (AES-GCM, ChaCha20-Poly1305).
- **0-RTT Resumption:** Returning clients send encrypted early data on first packet.

IPsec Suite & VPN Architectures

Network Layer

Protocol / Mode	Confidentiality	Integrity & Auth	Use Case
AH (Auth Header)	No (Plaintext)	Yes (Signs entire IP packet)	Integrity verification only
ESP (Encapsulating Security Payload)	Yes (Encrypted)	Yes (HMAC-SHA256)	Standard for all modern VPNs
Transport Mode	Only L4 payload	Headers unencrypted	Host-to-Host direct tunnels
Tunnel Mode	Entire original IP packet	New IP header appended	Site-to-Site & Remote Access VPN

VPN Modern Comparison:

- **IPsec (IKEv2):** High performance, kernel level, standard for enterprise router tunnels.
- **OpenVPN:** User-space SSL/TLS tunnel, highly configurable, traverses NAT easily.
- **WireGuard:** State-of-the-art (~4,000 lines of code vs 100k+ in OpenVPN). Uses Noise protocol, Curve25519, ChaCha20-Poly1305. Runs inside Linux kernel.

06 Perimeter Defense: Firewalls, IDS/IPS & DMZ Architecture

Firewall Evolution & Deep Packet Inspection

Perimeter

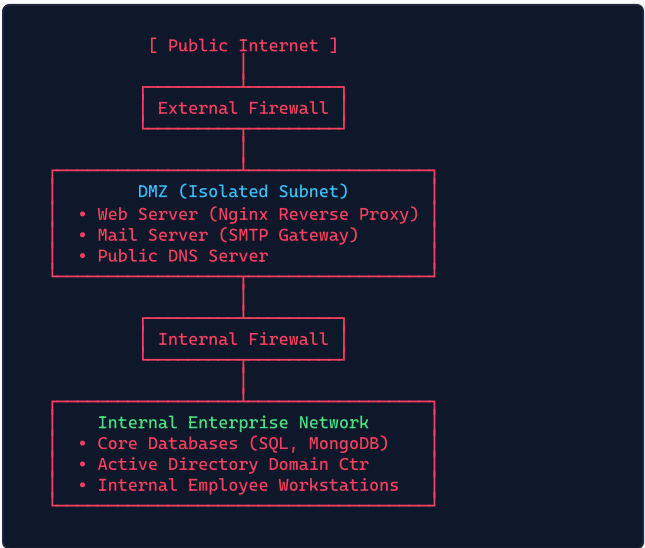
Generation	Type	Inspection Scope	Limitation
1st Gen	Stateless Packet Filter	IP headers, Port numbers, Protocol flags (L3/L4)	Blind to connection state; spoofable
2nd Gen	Stateful Inspection	Tracks connection states (SYN, ESTABLISHED)	Cannot inspect encrypted payload contents
3rd Gen	Application Proxy	Reconstructs L7 protocol (HTTP, FTP)	High latency; resource heavy
Next-Gen (NGFW)	Next-Gen Firewall (Palo Alto, Fortinet)	Deep Packet Inspection (DPI), TLS decryption, App-ID, IPS, Antivirus	Requires high CPU/ASIC crypto offloading

IDS vs IPS: An **IDS (Intrusion Detection System)** sits out-of-band via a TAP/SPAN port and generates alerts without affecting traffic. An **IPS (Intrusion Prevention System)** sits inline; it actively inspects and drops malicious packets before delivery.

DMZ (Demilitarized Zone) Architecture

Network Design

Isolates internet-facing services from mission-critical internal corporate assets:



Traffic rule: Internet may access DMZ. DMZ can never initiate unsolicited connections to the internal LAN.

07 Wireless Network Security & Enterprise Authentication

Wi-Fi Security Standard Evolution

802.11

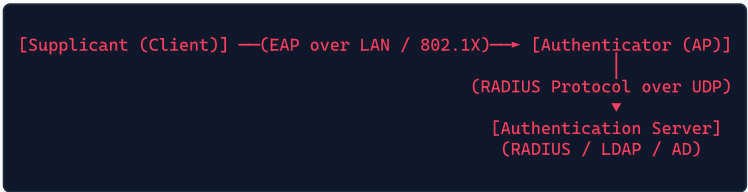
Standard	Encryption	Integrity	Security Status
WEP	RC4 (24-bit static IV)	CRC-32	Severely Broken (Cracked in seconds)
WPA	RC4 + TKIP (48-bit IV)	Michael	Deprecated (Vulnerable to Beck-Tews)
WPA2	AES-CCMP (128-bit)	CBC-MAC	Legacy Secure (Susceptible to KRACK & offline dictionary attacks)
WPA3	AES-GCMP (128/256-bit)	BIP-GMAC	Current Gold Standard (Resistant to offline brute force)

WPA3 SAE (Dragonfly Handshake): Replaces WPA2's 4-way handshake with *Simultaneous Authentication of Equals* based on zero-knowledge proofs. Even if an attacker captures the handshake, offline dictionary brute-forcing is mathematically impossible.

WPA-Personal vs WPA-Enterprise (802.1X)

Authentication

- WPA-Personal (PSK):** All devices share single static passphrase. If one employee leaks password, entire Wi-Fi is compromised.
- WPA-Enterprise (802.1X):** Every user authenticates with individual credentials or client certificates against a centralized **RADIUS / AAA Server** (Active Directory / FreeRADIUS).



- Protected Management Frames (802.11w / PMF):** Cryptographically signs deauth/disassociation frames to defeat Wi-Fi deauth kicking attacks.

08 Security Operations, Packet Analysis & Incident Response

Network Reconnaissance & Packet Forensics

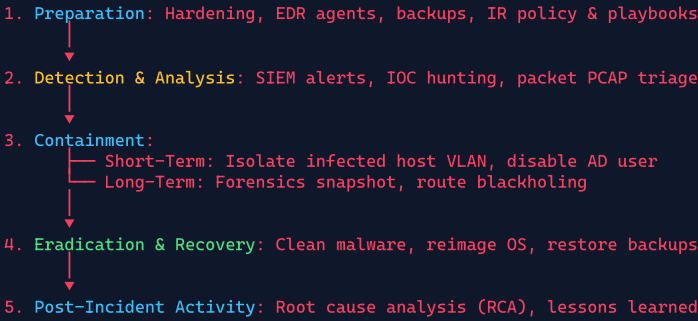
Tools

Core security analyst CLI toolchain syntax and techniques:

- **Nmap (Network Mapper):**
 - `nmap -sS -sV -O -p- 192.168.1.0/24` : Stealth SYN scan across all 65,535 ports with service version and OS fingerprinting.
 - `nmap --script vuln <target>` : Runs NSE vulnerability scripts.
- **tcpdump / Wireshark:**
 - `tcpdump -i eth0 -nn 'tcp[tcpflags] & (tcp-syn) != 0 and port 80'` : Captures incoming HTTP connection requests.
 - Wireshark TCP Stream Reassembly: Right click packet > *Follow* > *TCP Stream* to inspect unencrypted communications.
- **SIEM & SOAR (Splunk / Elastic):** Aggregates Syslog, Windows Event ID 4624 (Logon), Firewall drop logs to correlate multi-stage advanced persistent threats (APTs).

NIST Incident Response Lifecycle (SP 800-61)

Playbook



Chain of Custody: Forensic memory dumps (**Volatility**) and disk images (**dd** , **FTK Imager**) must be hashed immediately (SHA-256) to maintain legal evidence integrity.

09 Network Hardening Checklist & Cyber Defense Best Practices

Switch & Router Hardening

Infrastructure

- Disable unused interfaces and assign them to an unrouted blackhole VLAN (e.g. VLAN 999).
- Enforce SSHv2; permanently disable Telnet, HTTP, and SNMPv1/v2c (use SNMPv3 with auth & priv).
- Enable **BPDU Guard** and **Root Guard** on STP access ports to stop rogue switch topology hijacking.
- Configure Control Plane Policing (CoPP) to shield router CPU against denial-of-service packet flooding.

Identity & Access Control

IAM

- Mandate Multi-Factor Authentication (MFA) utilizing FIDO2 / WebAuthn hardware tokens or TOTP apps; prohibit SMS OTP.
- Enforce Principle of Least Privilege (PoLP) and Role-Based Access Control (RBAC).
- Isolate administrative management traffic to an out-of-band (OOB) dedicated network with dedicated bastion jump boxes.
- Eliminate shared administrative and root passwords.

Resilience & Data Protection

Continuity

- **3-2-1 Backup Strategy:** Maintain 3 copies of data on 2 distinct media types with 1 copy stored off-site and air-gapped / immutable against ransomware.
- Deploy continuous patch management (CISA Known Exploited Vulnerabilities catalog).
- Configure email defense records: SPF (**v=spf1**), DKIM cryptographic signatures, and strict DMARC (**p=reject**).